SOC Incident Investigation Report

Generated 2026-10-17 11:03:29 UTC - draft for analyst review

1. Executive Summary

The capture 'demo_combined_sim.pcap' (5,098 packets, 2117.88 s, 84 hosts) was analysed offline. The detection engine raised 15 alert(s): 4 High, 6 Medium, 1 Low, 4 Informational. The highest-priority indicators are: Periodic connections to 203.0.113.50:8443 (beacon-like timing) (192.168.1.50 -> 203.0.113.50); Port scan-like activity: 192.168.1.66 -> 192.168.1.20 (192.168.1.66 -> 192.168.1.20); Host sweep on TCP/445 from 192.168.1.66 (192.168.1.66 -> multiple). Overall heuristic risk is Critical (100/100). All findings are indicators that require analyst validation; none is confirmed malicious activity on its own.

2. Investigation Scope

Offline analysis of a single packet capture using the built-in heuristic engine. No live scanning, no external lookups, no payload extraction. Thresholds: see 'thresholds'.

3. PCAP File Metadata

- filename: demo_combined_sim.pcap
- format: pcap
- size_bytes: 3286339
- sha256: 2a5915463b1acef4b6aff51427a682b02b30442ab6af20ee139d9458c142bc89
- packets: 5098
- non_ip_packets: 0
- truncated: False
- first_packet_utc: 2025-10-09 08:53:21 UTC
- last_packet_utc: 2025-10-09 09:28:38 UTC
- duration_s: 2117.88

4. Network Overview

- packets: 5098
- total_bytes: 3204747
- duration_s: 2117.88
- avg_packets_per_s: 2.41
- avg_packet_size: 628.6
- unique_hosts: 84
- internal_hosts: 75
- external_hosts: 9
- flows: 730
- tcp_packets: 4292
- udp_packets: 766

- icmp_packets: 40

- top_protocol: HTTP-Alt

- top_talker: 192.168.1.77 (2.91 MB sent)

- top_dst_port: UDP/53

5. Key Findings

- [High/High] Periodic connections to 203.0.113.50:8443 (beacon-like timing): 36 TCP connections from 192.168.1.50 to 203.0.113.50:8443 between 2025-10-09 08:53:41 UTC and 2025-10-09 09:28:38 UTC.

- [High/High] Port scan-like activity: 192.168.1.66 -> 192.168.1.20: 208 distinct destination ports on 192.168.1.20; 214 SYN probe flows in 16.4s (~13 probes/s).

- [High/High] Host sweep on TCP/445 from 192.168.1.66: 42 distinct hosts probed on port 445; 42 SYN probe flows in 7.6s (~6 probes/s).

- [High/High] Possible DNS tunneling to tunnel-sim.example: 300 queries from 192.168.1.88 for names under tunnel-sim.example (1760001200-1760001317 epoch).

- [Medium/High] Many random-looking domain names (DGA-like pattern): 192.168.1.88 queried 38 distinct domains whose second-level labels look random (entropy >= 3.0, vowel ratio <= 0.3).

- [Medium/Medium] SMB connections to many hosts from one source: 192.168.1.66 contacted 42 distinct hosts on TCP/445 (SMB).

- [Medium/Medium] HTTP user-agent associated with scanning/attack tools: User-Agent contains: nikto (4 request(s)).

- [Medium/Medium] Large HTTP POST upload to files-sim.example: 1 cleartext HTTP request(s) declared Content-Length up to 2.80 MB (host: files-sim.example, path: /upload).

- [Medium/Low] Suspicious HTTP request path: Request to 192.168.1.20: GET /index.php?cmd=id

- [Medium/Low] Large outbound transfer to 198.51.100.25:8080: 192.168.1.77 sent 2.91 MB (2003 packets) to 198.51.100.25:8080/TCP over 16.1s (~177 KB/s) across 1 flow(s); 54.15 KB came back.

6. Prioritized Alerts

BEAC-2A1F9380 - Periodic connections to 203.0.113.50:8443 (beacon-like timing)

- Severity / confidence: High / High (Heuristic)

- Source -> destination: 192.168.1.50 -> 203.0.113.50:8443 (TCP)

- Time range: 2025-10-09 08:53:41 UTC to 2025-10-09 09:28:38 UTC

- Rule: BEACON-PERIODIC - >= 8 connections; CV <= 0.25 or >= 80% of intervals within +/-20%

- Evidence:

- 36 TCP connections from 192.168.1.50 to 203.0.113.50:8443 between 2025-10-09 08:53:41 UTC and 2025-10-09 09:28:38 UTC.

- Interval mean 59.92s, median 59.96s, std 1.30s, CV 0.022; 100% of intervals within +/-20% of the median.

- Mean bytes per connection: 677 B out / 575 B in (size CV out 0.00, in 0.00).

- 36 of 36 connections received a reply. First start times: 08:53:41, 08:54:40, 08:55:39, 08:56:38, 08:57:38.

- Scoring signals (5): external destination=True, non-standard port=True, consistent sizes=True, >=20 connections=True, very regular (CV<0.1)=True.

- Investigation steps:

- Identify the process on the source host that opens these connections (EDR, netstat/Sysmon event 3).

- Check the destination IP/domain reputation and whether other hosts contact it.

- Inspect jitter, payload sizes and any HTTP/TLS metadata (SNI, JA3) for the group.

- If unexplained, isolate the host and collect memory/disk artefacts before remediation.

- Possible false positives:

- Software update checks, telemetry, heartbeat/keep-alive, monitoring agents, mail/chat polling, NTP.

- Browser tabs or SaaS clients refreshing on a timer.

- MITRE ATT&CK: T1071.001 Application Layer Protocol: Web Protocols, T1571 Non-Standard Port

- Wireshark filter(s): ip.addr == 192.168.1.50 && ip.addr == 203.0.113.50 && tcp.port == 8443

SCAN-645FE0B1 - Port scan-like activity: 192.168.1.66 -> 192.168.1.20

- Severity / confidence: High / High (Heuristic)

- Source -> destination: 192.168.1.66 -> 192.168.1.20:n/a (TCP)

- Time range: 2025-10-09 09:03:20 UTC to 2025-10-09 09:03:36 UTC

- Rule: SCAN-VERTICAL - flows >= 20 and failed ratio >= 60% and (ports >= 20 on one host or hosts >= 15 on one port)

- Evidence:

- 208 distinct destination ports on 192.168.1.20; 214 SYN probe flows in 16.4s (~13 probes/s).

- 95% of probes got no answer or a reset (threshold 60%).

- Ports probed: 1-200, 445, 1433, 3306, 3389, 5432, 5900, 8080, 8443; 96% of probed port numbers are contiguous (dense range coverage).

- Open ports observed (SYN-ACK): 22, 80, 445, 3389.

- 98% of SYN probes used TCP window 1024 (consistent with, not proof of, Nmap defaults).

- Evidence is insufficient to confirm Nmap specifically: SYN probes with a small fixed window are only consistent with Nmap defaults; OS fingerprinting/NSE traffic would need payload or option-level review.

- Investigation steps:

- Determine whether 192.168.1.66 is an authorised scanner or asset-inventory host.

- Review firewall/IDS logs for the same source in the surrounding hours.

- If unauthorised, isolate the source and investigate how it was compromised (internal) or block it (external).

- Check the targets for newly opened ports/services shown in the evidence.

- Possible false positives:

- Authorised vulnerability scanner or asset discovery.

- Internet background scanning (if the source is external).

- MITRE ATT&CK: T1046 Network Service Discovery

- Wireshark filter(s): ip.addr == 192.168.1.66 && ip.addr == 192.168.1.20 | ip.src == 192.168.1.66 && tcp.flags.syn == 1 && tcp.flags.ack == 0 | ip.dst == 192.168.1.66 && tcp.flags.reset == 1

SCAN-67539DBB - Host sweep on TCP/445 from 192.168.1.66

- Severity / confidence: High / High (Heuristic)

- Source -> destination: 192.168.1.66 -> multiple:445 (TCP)

- Time range: 2025-10-09 09:03:20 UTC to 2025-10-09 09:03:27 UTC

- Rule: SCAN-HORIZONTAL - flows >= 20 and failed ratio >= 60% and (ports >= 20 on one host or hosts >= 15 on one port)

- Evidence:

- 42 distinct hosts probed on port 445; 42 SYN probe flows in 7.6s (~6 probes/s).

- 98% of probes got no answer or a reset (threshold 60%).

- Ports probed: 445; 0% of probed port numbers are contiguous (dense range coverage).

- Open ports observed (SYN-ACK): 445.

- 100% of SYN probes used TCP window 1024 (consistent with, not proof of, Nmap defaults).

- Evidence is insufficient to confirm Nmap specifically: SYN probes with a small fixed window are only consistent with Nmap defaults; OS fingerprinting/NSE traffic would need payload or option-level review.

- Investigation steps:

- Determine whether 192.168.1.66 is an authorised scanner or asset-inventory host.

- Review firewall/IDS logs for the same source in the surrounding hours.

- If unauthorised, isolate the source and investigate how it was compromised (internal) or block it (external).

- Check the targets for newly opened ports/services shown in the evidence.

- Possible false positives:

- Authorised vulnerability scanner or asset discovery.

- Internet background scanning (if the source is external).

- MITRE ATT&CK: T1046 Network Service Discovery

- Wireshark filter(s): ip.src == 192.168.1.66 | ip.src == 192.168.1.66 && tcp.flags.syn == 1 && tcp.flags.ack == 0 | ip.dst == 192.168.1.66 && tcp.flags.reset == 1

DNS-E5C04AD3 - Possible DNS tunneling to tunnel-sim.example

- Severity / confidence: High / High (Heuristic)

- Source -> destination: 192.168.1.88 -> resolver:53 (UDP)

- Time range: 2025-10-09 09:13:20 UTC to 2025-10-09 09:15:16 UTC

- Rule: DNS-TUNNEL - tunnel indicators >= 3 of 5 (unique subdomains >= 30, entropy >= 3.5, name length >= 52, TXT/NULL >= 50%, rate >= 100/min)

- Evidence:

- 300 queries from 192.168.1.88 for names under tunnel-sim.example (1760001200-1760001317 epoch).

- 300 unique subdomains; average subdomain length 45.0; 300 high-entropy names; 300 unusually long names; 100% TXT/NULL/ANY queries; peak 152 queries/min.

- 98 of 300 responses were NXDOMAIN.

- Sample names: qwb5pdkhx6pygpan2rlykei4iiaannkksumnlmytbx2k.t.tunnel-sim.example; avetwt6ul66ldqbwzb2xya4clmhp5wwq5gxsc3fnvxjv.t.tunnel-sim.example; utlfjt6kdfzcpwq52jdc7vnii2gk3xjd2sj5k57u6rs6.t.tunnel-sim.example

- Indicators met: many_unique_subdomains, high_entropy, long_names, txt_null_heavy, high_frequency.

- These are statistical indicators; the data inside the queries is not decoded.

- Investigation steps:

- Pivot in Wireshark with the suggested DNS filter and look at query names, record types and response sizes.

- Check whether the client runs software that legitimately generates many DNS names (CDN, AV cloud lookups, DNS-based blocklists).

- Review the domain's registration age/reputation using your approved internal tooling; do not browse to it.

- If suspicious: isolate the host, capture endpoint process-to-network mapping (EDR) and block the domain at the resolver.

- Possible false positives:

- CDN, antivirus or telemetry services that encode identifiers in hostnames.

- DNS-based blocklists / reputation lookups (e.g. mail filters).

- Wildcard DNS test tools.

- MITRE ATT&CK: T1071.004 Application Layer Protocol: DNS, T1572 Protocol Tunneling

- Wireshark filter(s): ip.addr == 192.168.1.88 && ip.addr == resolver && udp.port == 53 | dns.qry.name contains "tunnel-sim.example"

DNS-6F909C22 - Many random-looking domain names (DGA-like pattern)

- Severity / confidence: Medium / High (Heuristic)

- Source -> destination: 192.168.1.88 -> resolver:53 (UDP)

- Time range: 2025-10-09 09:15:17 UTC to 2025-10-09 09:16:16 UTC

- Rule: DNS-DGA - >= 10 random-looking domains from one source

- Evidence:

- 192.168.1.88 queried 38 distinct domains whose second-level labels look random (entropy >= 3.0, vowel ratio <= 0.3).

- 38 of 38 matching responses were NXDOMAIN.

- Samples: abfjigxfdnhtv.example; dmefnmggtxdgo.example; wnzdfusqpwwk.example; lkcihjcvmnbvdvp.example; rrigiuktssld.example; svqtxzdvadsrelsr.example

- Investigation steps:

- Check whether the host runs software known to use random names (browser captive-portal checks, Chromium DNS probes).

- Look for the process responsible via EDR; most DGAs are produced by malware or by coverage/probing tools.

- Block at the resolver and review other hosts querying the same names.

- Possible false positives:

- Browser/OS connectivity probes generate a few random names (Chromium), usually fewer than the threshold.

- Security scanners or sandbox detonation.

- MITRE ATT&CK: T1568.002 Dynamic Resolution: Domain Generation Algorithms

- Wireshark filter(s): ip.addr == 192.168.1.88 && ip.addr == resolver && udp.port == 53

REMO-13AA9CE3 - SMB connections to many hosts from one source

- Severity / confidence: Medium / Medium (Heuristic)

- Source -> destination: 192.168.1.66 -> multiple:445 (TCP)

- Time range: 2025-10-09 09:03:20 UTC to 2025-10-09 09:03:27 UTC

- Rule: REMOTE-SMB-SWEEP - distinct destination hosts >= 5 on one SMB port

- Evidence:

- 192.168.1.66 contacted 42 distinct hosts on TCP/445 (SMB).

- 1 host(s) completed the TCP handshake; this does NOT show a successful login.

- Total flows: 42.

- Investigation steps:

- Identify the source host and its owner; check whether remote administration from it is expected.

- Review authentication logs (Windows Security 4624/4625, SSH auth.log) on the destination(s).

- In Wireshark filter on the source and port to review timing and session lengths.

- Possible false positives:

- Admin/inventory/backup tools legitimately contact many hosts.

- Vulnerability scanners.

- MITRE ATT&CK: T1021.002 Remote Services: SMB/Windows Admin Shares

- Wireshark filter(s): ip.src == 192.168.1.66

HTTP-A6F73B4E - HTTP user-agent associated with scanning/attack tools

- Severity / confidence: Medium / Medium (Heuristic)

- Source -> destination: 192.168.1.66 -> 192.168.1.20:80 (TCP)

- Time range: 2025-10-09 09:03:34 UTC to 2025-10-09 09:03:36 UTC

- Rule: HTTP-SCANNER-UA - user-agent matches scanner keyword list

- Evidence:

- User-Agent contains: nikto (4 request(s)).

- Example: Nikto/2.1.6 (SIMULATED)

- User-agents are trivially spoofed; absence/presence is only an indicator.

- Investigation steps:

- Open the request/handshake in Wireshark using the suggested filter.

- Confirm the client application and destination are expected.

- Review proxy/web-server logs for response codes; the capture alone may not show success.

- Possible false positives:

- Authorised vulnerability scans.

- Another tool reusing the string.

- MITRE ATT&CK: T1595.002 Active Scanning: Vulnerability Scanning

- Wireshark filter(s): ip.addr == 192.168.1.66 && ip.addr == 192.168.1.20 && tcp.port == 80 | ip.src == 192.168.1.66 && http.request

EXFI-FA168C3A - Large HTTP POST upload to files-sim.example

- Severity / confidence: Medium / Medium (Heuristic)

- Source -> destination: 192.168.1.77 -> 198.51.100.25:8080 (TCP)

- Time range: 2025-10-09 09:08:20 UTC to 2025-10-09 09:08:20 UTC

- Rule: EXFIL-HTTP-POST - POST/PUT Content-Length >= 1000000

- Evidence:

- 1 cleartext HTTP request(s) declared Content-Length up to 2.80 MB (host: files-sim.example, path: /upload).

- Content-Length is what the client declared; the body itself is not stored or analysed.

- Investigation steps:

- Identify the process/user on the internal host responsible for the transfer (EDR, proxy logs).

- Check whether the destination is an approved backup/cloud/file-sharing service.

- Review what data was accessible to that host around that time (file-server and DLP logs).

- If unapproved: block the destination, preserve evidence and start incident handling.

- Possible false positives:

- Backups, cloud sync (OneDrive/Dropbox), software uploads, video conferencing, crash-dump uploads.

- Large legitimate file shares or mail attachments.

- Legitimate web-form/file uploads.

- MITRE ATT&CK: T1048.003 Exfiltration Over Unencrypted Non-C2 Protocol

- Wireshark filter(s): ip.addr == 192.168.1.77 && ip.addr == 198.51.100.25 && tcp.port == 8080

HTTP-01041F97 - Suspicious HTTP request path

- Severity / confidence: Medium / Low (Heuristic)

- Source -> destination: 192.168.1.66 -> 192.168.1.20:80 (TCP)

- Time range: 2025-10-09 09:03:36 UTC to 2025-10-09 09:03:36 UTC

- Rule: HTTP-PATH - path matches suspicious-pattern list

- Evidence:

- Request to 192.168.1.20: GET /index.php?cmd=id

- Matched: command-like parameter.

- The response code/body was not evaluated here, so success cannot be confirmed.

- Investigation steps:

- Open the request/handshake in Wireshark using the suggested filter.

- Confirm the client application and destination are expected.

- Review proxy/web-server logs for response codes; the capture alone may not show success.

- Possible false positives:

- Vulnerability scanners, applications with long encoded query strings.

- MITRE ATT&CK: T1190 Exploit Public-Facing Application

- Wireshark filter(s): ip.addr == 192.168.1.66 && ip.addr == 192.168.1.20 && tcp.port == 80 | ip.src == 192.168.1.66 && http.request

EXFI-95280FC2 - Large outbound transfer to 198.51.100.25:8080

- Severity / confidence: Medium / Low (Heuristic)

- Source -> destination: 192.168.1.77 -> 198.51.100.25:8080 (TCP)

- Time range: 2025-10-09 09:08:20 UTC to 2025-10-09 09:08:36 UTC

- Rule: EXFIL-RATIO - bytes_out >= 10000000 OR (bytes_out >= 1000000 AND out/in >= 10.0)

- Evidence:

- 192.168.1.77 sent 2.91 MB (2003 packets) to 198.51.100.25:8080/TCP over 16.1s (~177 KB/s) across 1 flow(s); 54.15 KB came back.

- Outbound-to-inbound ratio 53.7:1. Large-volume rule not met (>= 10.00 MB); ratio rule met (>= 10.0:1 and >= 1.00 MB).

- Byte counts are frame sizes seen in the capture; encrypted content cannot be inspected, so the data type is unknown.

- Investigation steps:

- Identify the process/user on the internal host responsible for the transfer (EDR, proxy logs).

- Check whether the destination is an approved backup/cloud/file-sharing service.

- Review what data was accessible to that host around that time (file-server and DLP logs).

- If unapproved: block the destination, preserve evidence and start incident handling.

- Possible false positives:

- Backups, cloud sync (OneDrive/Dropbox), software uploads, video conferencing, crash-dump uploads.

- Large legitimate file shares or mail attachments.

- MITRE ATT&CK: T1048 Exfiltration Over Alternative Protocol

- Wireshark filter(s): ip.addr == 192.168.1.77 && ip.addr == 198.51.100.25 && tcp.port == 8080

SCAN-95D4BCAA - ICMP sweep-like activity from 192.168.1.66

- Severity / confidence: Low / Medium (Heuristic)

- Source -> destination: 192.168.1.66 -> multiple:n/a (ICMP)

- Time range: 2025-10-09 09:03:30 UTC to 2025-10-09 09:03:31 UTC

- Rule: SCAN-ICMP-SWEEP - >= 15 distinct ICMP destinations from one source

- Evidence:

- 192.168.1.66 sent ICMP to 30 distinct hosts; 10 replied.

- ICMP type/code are not used to prove host discovery intent.

- Investigation steps:

- Determine whether 192.168.1.66 is an authorised scanner or asset-inventory host.

- Review firewall/IDS logs for the same source in the surrounding hours.

- If unauthorised, isolate the source and investigate how it was compromised (internal) or block it (external).

- Check the targets for newly opened ports/services shown in the evidence.

- Possible false positives:

- Network monitoring (ping checks), traceroute, inventory tools.

- MITRE ATT&CK: T1018 Remote System Discovery

- Wireshark filter(s): ip.src == 192.168.1.66 | ip.src == 192.168.1.66 && tcp.flags.syn == 1 && tcp.flags.ack == 0 | ip.dst == 192.168.1.66 && tcp.flags.reset == 1

BEAC-0640C5C1 - Periodic connections to 203.0.113.123:123 (beacon-like timing)

- Severity / confidence: Informational / Low (Heuristic)

- Source -> destination: 192.168.1.10 -> 203.0.113.123:123 (UDP)

- Time range: 2025-10-09 08:53:25 UTC to 2025-10-09 09:05:09 UTC

- Rule: BEACON-PERIODIC - >= 8 connections; CV <= 0.25 or >= 80% of intervals within +/-20%

- Evidence:

- 12 UDP connections from 192.168.1.10 to 203.0.113.123:123 between 2025-10-09 08:53:25 UTC and 2025-10-09 09:05:09 UTC.

- Interval mean 64.00s, median 64.00s, std 0.00s, CV 0.000; 100% of intervals within +/-20% of the median.

- Mean bytes per connection: 90 B out / 90 B in (size CV out 0.00, in 0.00).

- 12 of 12 connections received a reply. First start times: 08:53:25, 08:54:29, 08:55:33, 08:56:37, 08:57:41.

- Scoring signals (3): external destination=True, non-standard port=False, consistent sizes=True, >=20 connections=False, very regular (CV<0.1)=True.

- Port 123 is on the benign-periodic list (e.g. NTP/DNS); severity capped at Informational.

- Investigation steps:

- Identify the process on the source host that opens these connections (EDR, netstat/Sysmon event 3).

- Check the destination IP/domain reputation and whether other hosts contact it.

- Inspect jitter, payload sizes and any HTTP/TLS metadata (SNI, JA3) for the group.

- If unexplained, isolate the host and collect memory/disk artefacts before remediation.

- Possible false positives:

- Software update checks, telemetry, heartbeat/keep-alive, monitoring agents, mail/chat polling, NTP.

- Browser tabs or SaaS clients refreshing on a timer.

- MITRE ATT&CK: none (evidence insufficient for a mapping)

- Wireshark filter(s): ip.addr == 192.168.1.10 && ip.addr == 203.0.113.123 && udp.port == 123

TLS-38D4DE99 - Repeated connections to uncommon destination 203.0.113.50

- Severity / confidence: Informational / Low (Heuristic)

- Source -> destination: 192.168.1.50 -> 203.0.113.50:8443 (TCP)

- Time range: 2025-10-09 08:53:41 UTC to 2025-10-09 09:28:38 UTC

- Rule: TLS-UNCOMMON-REPEAT - >= 10 connections to a destination not on the allow-list

- Evidence:

- 36 web/TLS connections to c2-sim.example:8443; name is not on the built-in common-services list.

- 'Uncommon' only means 'not on a small allow-list'; most such destinations are legitimate.

- Investigation steps:

- Open the request/handshake in Wireshark using the suggested filter.

- Confirm the client application and destination are expected.

- Review proxy/web-server logs for response codes; the capture alone may not show success.

- Possible false positives:

- Any SaaS/API service not on the small built-in list.

- MITRE ATT&CK: none (evidence insufficient for a mapping)

- Wireshark filter(s): ip.addr == 192.168.1.50 && ip.addr == 203.0.113.50 && tcp.port == 8443 | ip.addr == 203.0.113.50 && tls.handshake.type == 1

HTTP-48691562 - HTTP requests addressed to a raw IP address

- Severity / confidence: Informational / Low (Heuristic)

- Source -> destination: 192.168.1.66 -> 192.168.1.20:80 (TCP)

- Time range: 2025-10-09 09:03:34 UTC to 2025-10-09 09:03:36 UTC

- Rule: HTTP-IPHOST - Host header is an IP literal

- Evidence:

- 4 requests used a bare IP as Host (192.168.1.20).

- Investigation steps:

- Open the request/handshake in Wireshark using the suggested filter.

- Confirm the client application and destination are expected.

- Review proxy/web-server logs for response codes; the capture alone may not show success.

- Possible false positives:

- Internal appliances, device web UIs, APIs.

- MITRE ATT&CK: none (evidence insufficient for a mapping)

- Wireshark filter(s): ip.addr == 192.168.1.66 && ip.addr == 192.168.1.20 && tcp.port == 80 | ip.src == 192.168.1.66 && http.request

HTTP-866C862D - Scripted or unusual HTTP client

- Severity / confidence: Informational / Low (Heuristic)

- Source -> destination: 192.168.1.77 -> 198.51.100.25:8080 (TCP)

- Time range: 2025-10-09 09:08:20 UTC to 2025-10-09 09:08:20 UTC

- Rule: HTTP-SCRIPT-UA - user-agent is a scripting library or absent

- Evidence:

- Client indicators: python-requests (1 request(s)) to files-sim.example.

- Investigation steps:

- Open the request/handshake in Wireshark using the suggested filter.

- Confirm the client application and destination are expected.

- Review proxy/web-server logs for response codes; the capture alone may not show success.

- Possible false positives:

- Admin scripts, package managers, health checks, developer tools.

- MITRE ATT&CK: none (evidence insufficient for a mapping)

- Wireshark filter(s): ip.addr == 192.168.1.77 && ip.addr == 198.51.100.25 && tcp.port == 8080 | ip.src == 192.168.1.77 && http.request

7. IOC List

Indicators referenced by alerts. Validate before blocking; values are defanged.

| Type | Value | Count | Related alerts |

|---|---|---|---|

| ip | 198[.]51[.]100[.]25 | 3005 | EXFI-FA168C3A, EXFI-95280FC2, HTTP-866C862D |

| ip | 203[.]0[.]113[.]50 | 432 | BEAC-2A1F9380, TLS-38D4DE99 |

| domain | tunnel-sim[.]example | 300 | DNS-E5C04AD3 |

| domain | c2-sim[.]example | 36 | TLS-38D4DE99 |

| ip | 203[.]0[.]113[.]123 | 24 | BEAC-0640C5C1 |

| user_agent | Nikto/2[.]1[.]6 (SIMULATED) | 4 | HTTP-A6F73B4E |

| domain | files-sim[.]example | 2 | EXFI-FA168C3A, HTTP-866C862D |

| domain | abfjigxfdnhtv[.]example | 1 | DNS-6F909C22 |

| domain | bcngfwpqxdidmsh[.]example | 1 | DNS-6F909C22 |

| domain | dmefnmggtxdgo[.]example | 1 | DNS-6F909C22 |

| domain | gmzkqklstjol[.]example | 1 | DNS-6F909C22 |

| domain | lkcihjcvmnbvdvp[.]example | 1 | DNS-6F909C22 |

| domain | mkrrcnedpnpttd[.]example | 1 | DNS-6F909C22 |

| domain | rrigiuktssld[.]example | 1 | DNS-6F909C22 |

| domain | svqtxzdvadsrelsr[.]example | 1 | DNS-6F909C22 |

| domain | wfnngbthrjluc[.]example | 1 | DNS-6F909C22 |

| domain | wnzdfusqpwwk[.]example | 1 | DNS-6F909C22 |

| user_agent | python-requests/2[.]31 (SIMULATED) | 1 | HTTP-866C862D |

| internal_host | 192[.]168[.]1[.]50 | 0 | BEAC-2A1F9380 |

| internal_host | 192[.]168[.]1[.]66 | 0 | SCAN-645FE0B1, SCAN-67539DBB, REMO-13AA9CE3, SCAN-95D4BCAA |

| internal_host | 192[.]168[.]1[.]88 | 0 | DNS-E5C04AD3, DNS-6F909C22 |

| internal_host | 192[.]168[.]1[.]77 | 0 | EXFI-FA168C3A, EXFI-95280FC2 |

| internal_host | 192[.]168[.]1[.]10 | 0 | BEAC-0640C5C1 |

8. MITRE ATT&CK Mapping

| Technique | Tactic | Confidence | Rationale | Alerts |

|---|---|---|---|---|

| T1595.002 Active Scanning: Vulnerability Scanning | Reconnaissance | Medium | User-agent of a known scanning tool. | HTTP-A6F73B4E |

| T1190 Exploit Public-Facing Application | Initial Access | Low | Exploit-like request sent to an internal web service. | HTTP-01041F97 |

| T1018 Remote System Discovery | Discovery | Medium | Internal source sent ICMP to many hosts (host discovery-like). | SCAN-95D4BCAA |

| T1046 Network Service Discovery | Discovery | High | Many ports/services probed on a host from an internal source. | SCAN-645FE0B1, SCAN-67539DBB |

| T1021.002 Remote Services: SMB/Windows Admin Shares | Lateral Movement | Medium | One source connecting to SMB on many hosts. | REMO-13AA9CE3 |

| T1071.001 Application Layer Protocol: Web Protocols | Command and Control | High | Regular periodic connections are consistent with C2 check-ins; payload not inspected, so protocol use is unconfirmed. | BEAC-2A1F9380 |

| T1071.004 Application Layer Protocol: DNS | Command and Control | High | Many high-entropy, long DNS names under one domain. | DNS-E5C04AD3 |

| T1568.002 Dynamic Resolution: Domain Generation Algorithms | Command and Control | High | Many random-looking domain names queried by one source. | DNS-6F909C22 |

| T1571 Non-Standard Port | Command and Control | High | Periodic traffic on a port outside the common-service list. | BEAC-2A1F9380 |

| T1572 Protocol Tunneling | Command and Control | High | Pattern consistent with data encoded into DNS names. | DNS-E5C04AD3 |

| T1048 Exfiltration Over Alternative Protocol | Exfiltration | Low | Unusually large outbound volume to one destination (could be legitimate). | EXFI-95280FC2 |

| T1048.003 Exfiltration Over Unencrypted Non-C2 Protocol | Exfiltration | Medium | Large cleartext HTTP upload. | EXFI-FA168C3A |

9. Evidence and Limitations

- Findings are heuristic indicators computed from packet metadata; they are not confirmed malicious activity.

- Much of the traffic is encrypted (TLS); payloads, URLs and file contents cannot be inspected. Only metadata (SNI, JA3, sizes, timing) is available.

- Capture position matters: traffic that did not cross the capture point is invisible, and NAT can hide the real source host.

- Scan, brute-force and lateral-movement rules show connection patterns only; they do not show authentication success or file contents.

10. False-Positive Considerations

- Admin scripts, package managers, health checks, developer tools.

- Admin/inventory/backup tools legitimately contact many hosts.

- Another tool reusing the string.

- Any SaaS/API service not on the small built-in list.

- Authorised vulnerability scanner or asset discovery.

- Authorised vulnerability scans.

- Backups, cloud sync (OneDrive/Dropbox), software uploads, video conferencing, crash-dump uploads.

- Browser tabs or SaaS clients refreshing on a timer.

- Browser/OS connectivity probes generate a few random names (Chromium), usually fewer than the threshold.

- CDN, antivirus or telemetry services that encode identifiers in hostnames.

- DNS-based blocklists / reputation lookups (e.g. mail filters).

- Internal appliances, device web UIs, APIs.

- Internet background scanning (if the source is external).

- Large legitimate file shares or mail attachments.

- Legitimate web-form/file uploads.

- Network monitoring (ping checks), traceroute, inventory tools.

- Security scanners or sandbox detonation.

- Software update checks, telemetry, heartbeat/keep-alive, monitoring agents, mail/chat polling, NTP.

- Vulnerability scanners, applications with long encoded query strings.

- Vulnerability scanners.

- Wildcard DNS test tools.

11. Recommended Containment and Remediation

- [Beaconing] Isolate the source host from the network pending triage.

- [Beaconing] Block the destination IP/domain at the firewall/proxy after validation.

- [Beaconing] Collect process, memory and persistence artefacts with EDR; identify the program making the connections.

- [DNS] Block or sinkhole the suspicious domain(s) at the resolver.

- [DNS] Restrict outbound DNS to approved resolvers and enable DNS logging.

- [DNS] Alert on long/high-entropy query patterns and high NXDOMAIN rates.

- [Exfiltration] Determine what data the host could access and whether it left the network (DLP, proxy, cloud logs).

- [Exfiltration] Block the destination if unapproved and preserve evidence.

- [Exfiltration] Enforce egress filtering and upload-size alerting.

- [HTTP] Review web-server logs for the matching requests and responses.

- [HTTP] Patch/harden the targeted web application and enable a WAF where appropriate.

- [Remote Services] Restrict SMB/RDP/SSH to management networks or VPN.

- [Remote Services] Enforce MFA and account lockout; review authentication logs.

- [Scan] Confirm whether the scanner is authorised; if not, isolate the source and review how it was compromised.

- [Scan] Review exposed services on the targeted hosts and close what is not needed.

- [Scan] Add IDS rules/rate limits for SYN scans and sweeps.

- [TLS] Review the destination/SNI with threat intelligence; consider TLS inspection policy where lawful.

12. Analyst Conclusion

EXAMPLE ONLY (simulated data): the indicators above match the simulated scenarios injected by sample_data/generate_samples.py: a ~60-second beacon to 203.0.113.50:8443, a scan from 192.168.1.66, DNS tunnel/DGA-like queries from 192.168.1.88 and a ~2.8 MB upload from 192.168.1.77. In a real case the analyst would validate each finding with endpoint and log evidence before concluding.